

GOLD Token

Altın destekli dijital token projesi

Hiç teknik bilmeyen biri de anlasın diye yazıldı

İki cümleyle bu proje ne?

Bir GOLD = bir gram gerçek altın. Sahip olduğun token'ın karşılığı kasada bekliyor, istediğin zaman satarsın, transfer edersin, 1 kiloyu geçtiğinde de fiziksel olarak teslim alırsın. O kadar.

Not: Burada işin özünü konuşacağız. Detaylı teknik tasarıma ihtiyacın olursa repo içindeki **docs/system-design.md** var, tam 972 satır.

1. Önce hikaye: bu proje neden var?

Diyelim ki elinde bir miktar paran var ve altın almak istiyorsun. Bugün ne yapıyorsun? Ya kuyumcuya gidiyorsun, ya bankaya. Kuyumcuda makas var, bankada saklama ücreti var, ikisinde de fiziksel altını saklamak ayrı bir dert.

GOLD bu işi şöyle yapıyor: kasada gerçek altın çubuklar duruyor, biz bu çubukları senin adına bir miktar 'tahsis' ediyoruz, karşılığında telefonundaki cüzdana 'GOLD' adında bir token geliyor. Bu token bir kağıt parçası değil, gerçek bir gram altına bağlı. Hatta hangi çubuğa bağlı olduğunu seri numarasıyla bile görebilirsin.

Avantajı? Telefondan alıyorsun, telefondan satıyorsun. İstersen arkadaşına gönderiyorsun. Gerçekten elinde tutmak istersen (en az 1 kilo) kargolatiyorsun. Kasa, sigorta, denetim — hepsi arka planda hallediliyor.

Peki PAXG, XAUT zaten var, sen ne farklısın?

Üç şey farklı: **(1)** Onlar 1 ons üzerinden çalışıyor, biz 1 gram. Yani 100 dolarlık altın almak isteyen Türk öğrenci de girebiliyor. **(2)** Onlar tek ülkede, biz dört ülkede lisanslıyız (Türkiye, İsviçre, BAE, Liechtenstein) — bir tanesi kapanırsa diğeri ayakta. **(3)** Onların altını üçüncü taraf rafineriden geliyor, bizim Çorum'da kendi rafinerimiz var. Yani altın bizim, kasa bizim, token bizim. Baştan sona kontrol.

2. Kullanıcı tarafından ne yaşıyor?

En sade haliyle anlatayım. Sen uygulamaya giriyorsun, ben de sistem tarafında ne olduğunu yan yana söyleyeyim:

- **Önce kayıt:** E-posta, telefon, sonra kimlik fotoğrafı + selfie. Türkiye'deyse MERNİS'e bakılıyor, İsviçre'deyse pasaport okunuyor. Bu işlem 'KYC' deniyor — yani 'müşterini tanı'. Bir kere yapıyorsun, bitiyor.
- **Sonra para yatırma:** Banka havalesi, kart, ne kolayına geliyorsa. TL, USD, EUR, AED — hangi arenadansan o para birimi.
- **Sipariş veriyorsun:** 'Bana 50 gram GOLD ver' diyorsun. Sistem o anki altın fiyatını gösteriyor, onaylıyorsun.
- **Arka planda kasaya gidiliyor:** Müsait bir çubuk seçiliyor, 50 gramı senin adına işaretleniyor. Bu kayda 'tahsisat' diyoruz.
- **5 kişiden 3'ü 'tamam' diyor:** Hazine, uyum müdürü, denetçi, teknik, CIO — bunlardan üçü onaylamadan token basılmıyor. Tek kişinin yetkisi yok, kötü niyetli birinin sistemi çalması imkânsız.
- **Token cüzdanına geliyor:** Ethereum üzerinde mint işlemi yapılıyor, 50 GOLD senin cüzdanına düşüyor. Tüm bu süre 2-3 dakika.
- **İstedğini yap:** Sat, gönder, beklet, ya da 1 kiloyu aştığında 'fiziksel istiyorum' de — Brink's ile evine kargolatalım.

Satarken ne oluyor?

Tersini yapıyoruz. Sen 'satıyorum' diyorsun, token cüzdanından alınıp 'yakılıyor' (burn). Yakılma kelimesinden korkma — Ethereum'da bir token'ı sonsuza kadar yok etmek demek bu. Karşılığında kasada o gramlık çubuk tekrar 'boşa çıkıyor' ve sana hesabına paran yatırıyor.

3. Sistemin parçaları neler?

Sistemi 4 katmana bölelim. Her birinin işi farklı ama hepsi birbiriyle konuşuyor:

A. Blokzincirdeki akıllı sözleşmeler

Bunlar Ethereum'da çalışan, Solidity diliyle yazılmış kod parçaları. Bir kere yazıldıktan sonra kimse müdahale edemiyor, herkes okuyabiliyor:

- **GoldToken:** Asıl token. Transfer et, bakiye gör, onay ver — temel ERC-20 işleri.
- **ComplianceRegistry:** Kimin alıp satabileceğini tutan defter. KYC yapmamış birine token gitmez.
- **MintController:** Yeni token basımı. Çoklu imza olmadan çalışmaz, denetim 35 günden eskitse de durur.
- **BurnController:** Token yakımı. Satış ya da fiziksel teslim olduğunda devreye girer.
- **ReserveOracle:** Aylık denetim sonucunu blokzincire yazan defter. Bir kez yazıldı mı silinmiyor.
- **PriceOracle:** Chainlink üzerinden anlık altın fiyatı.
- **Treasury Safe:** Sistemin patronu, ama tek patron değil — 5 kişiden 3'ünün imzası gerek.

B. Backend (yani sunucu) servisleri

Blokzincir her şeyi yapamıyor — kimlik doğrulamak, bankayla konuşmak, kasaya komut göndermek gibi işler için klasik sunucu servisleri lazım. Go diliyle yazılmış mikroservisler var, her biri tek bir iş yapıyor:

- **Auth:** Giriş, 2 faktörlü doğrulama, oturum yönetimi.
- **KYC/AML:** Kimliğini doğrular, yaptırım listelerine bakar.
- **Wallet:** Sana saklamalı cüzdan açar ya da kendi cüzdanını bağlatır.
- **Order:** Alış/satış/itfa siparişlerini takip eder.
- **Mint/Burn:** Kasa ile blokzincir arasındaki köprü. En kritik servis.
- **Price Oracle:** Birden fazla kaynaktan altın fiyatı toplar, manipülasyonu yakalar.
- **Proof-of-Reserve:** Aylık denetim verisini toplar, Merkle ağacı kurar, IPFS'e atar.
- **Compliance Engine:** Şüpheli işlemleri tarar, büyük transferlerde 'Travel Rule' uygular.
- **Notification + Reporting:** E-posta/SMS gönderir, devlete rapor üretir.

C. Fiziksel altyapı — kasalar

Bu kısım çoğu kişinin atladığı yer: altın gerçek bir yerde duruyor. Tek kasa yok, dört yerde dağıtık:

Lokasyon	Görev	Arena
Çorum — kendi rafinerimiz	Üretim + birincil kasa	TR
İstanbul — BIST Kıymetli Madenler	Yerel saklama	TR
Zürih — Brink's / Loomis	Avrupa kasası	CH / EU
Dubai — DMCC / Brink's	Körfez kasası	AE

D. Kullanıcının gördüğü kısım

- **Web uygulaması (Next.js):** En tam fonksiyonlu kanal — onboarding, alış/satış, portföy, denetim raporları.
- **iOS ve Android uygulamaları:** Mobil odaklı, native (Swift + Kotlin).
- **Kurumsal API:** Bankaların ve piyasa yapımcıların kullanması için.
- **verify.gold.example:** Halka açık doğrulama portalı. Kimse üye olmadan girip 'şu cüzdanın altını gerçekten var mı' diye sorabilir.

4. Sana neden güveneyim?

İşin can damarı bu soru. Türkiye'de FTX olduğunu görmüş, Celsius olduğunu görmüş bir insan haklı olarak soruyor. Üç katmanlı bir cevabımız var:

Birinci katman: Tahsisli rezerv — kesirli yok

Bankalar genelde 'kesirli rezerv' ile çalışır: 100 lira mevduat topladığında belki 10 lirayı tutar, gerisini kredi olarak verir. Bizde böyle bir şey yok. Sistemde 1.000 token varsa, kasada 1.000 gram altın var. Hangi çubuğun kime ait olduğu da **bar_allocations** diye bir tabloda kayıtlı.

İkinci katman: Aylık Big Four denetimi

Her ayın 1'inde Big Four diye bilinen dört büyük denetim firmasından biri (PwC, Deloitte, EY veya KPMG) dört kasayı fiziksel olarak sayıyor. Her çubuğun seri numarası, ağırlığı, saflığı kayda giriyor.

- Tüm liste 'Merkle ağacı' diye bir veri yapısına sokuluyor — bunun özelliği şu: tek bir çubuk değişse ağacın kökü değişir, anlarsın.
- Denetçi bu kökü EIP-712 standardıyla imzalıyor (sahte imza atılamaz).
- Tam rapor IPFS'e atılıyor — IPFS'in özelliği şu: bir kez yüklendi mi dosya hep aynı 'adres' altında, değiştiremezsin.
- Özet hash blokzincire yazılıyor — geri dönülmez.
- Denetim 35 günden eski olursa MintController yeni token basmayı reddediyor. Yani 'denetim atlayalım' gibi bir oyun yok.

Üçüncü katman: Çubuk bazında doğrulama

Sen verify.gold.example'a cüzdan adresini yazıyorsun. Sistem diyor ki: 'Senin 50 gramın Çorum kasasında, TR-2026-00428 seri numaralı çubukta tahsisli.' Hatta sana Merkle proof veriyor ki, sen bunu blokzincirdeki ReserveOracle sözleşmesinde bağımsız olarak doğrulayabilirsin. Bize güvenmek zorunda bile değilsin — matematik söylüyor.

5. Bunu nasıl yapacağız? — Yol haritası

İlk günden 'her şeyi yapalım' demek tehlikeli. Onun yerine altı faza böldük. Her faz öncekinin üstüne bir özellik ekliyor, hiçbir faz aceleye gelmiyor:

Faz 0 — Temeli atalım (Ay 0-2)

- Ekibi topla: tech lead + 2 smart contract + 2 backend + 1 SRE.
- Ethereum testnet'te ilk kontratları kur — GoldToken, ComplianceRegistry, MintController iskeletleri.
- Yerel geliştirme ortamı (docker-compose ile her şey ayakta) ve CI/CD.
- Güvenlik tehdit modeli atölyesi — neyin nereden saldırı yiyebileceğini konuşalım.
- Tedarikçilerle pilot: Sumsu (KYC), Fireblocks (cüzdan saklama).

Faz 1 — Türkiye MVP'si (Ay 2-6)

- Türkiye için baştan sona iş akışı: kayıt → TL yatırma → mint → cüzdan → satış → TL çekme.
- Tek kasa: Çorum.
- PoR manuel — aylık tablo ve manuel imza yetiyor şimdilik.
- Çalışanlar arası alfa testi (önce kendimiz yiyoruz).
- CMB'ye (Sermaye Piyasası Kurulu) ön başvuru.

Faz 2 — Denetim otomasyonu + İsviçre (Ay 6-10)

- Otomatik PoR: ReserveOracle deploy, Merkle ağacı, IPFS.
- Zürih kasası entegre.
- USD, EUR, CHF para giriş-çıkışı.
- FINMA için SRO başvurusu.
- İlk dış güvenlik denetimi (OpenZeppelin).
- Sepolia testnet'te halka açık beta.

Faz 3 — Mainnet lansmanı (Ay 10-14)

- Ethereum mainnet'e gerçek deploy + Treasury Safe devri.
- İkinci ve üçüncü güvenlik denetimleri (Trail of Bits, Spearbit).
- 10 milyon dolar başlangıç rezervi → ilk mint.
- TR ve CH arenaları canlı.
- 1-2 borsada listeleme + 1 piyasa yapıcı.
- verify.gold.example halka açık.

Faz 4 — Küresele açıl (Ay 14-24)

- Dubai VARA lisansı, BAE arenası.
- Liechtenstein üzerinden MiCA (Avrupa pasaportu).
- Avalanche ve BNB Chain'e LayerZero köprüsü.
- DEX'lerde likidite havuzları.
- Kurumsal API ve banka ortaklıkları.
- Şeriat uyumlu varyant.

Faz 5 — Olgun ürün (Ay 24+)

- Layer 2 (Base, Arbitrum) genişleme.
- Tokenize altın ETF köprüsü.
- Altın leasing / yield ürünleri.
- Açık finansal API (yetkilendirme ile).

6. Hangi teknolojileri seçtik, niye?

Bir kuralımız var: 'hipster' teknoloji yok. Her seçim, 'denetim havuzu geniş mi, operasyonel olarak yorulmaz mıyız' diye sorularak yapıldı:

Katman	Seçim	Niye
Akıllı sözleşme dili	Solidity 0.8.24	En geniş denetim havuzu
Sözleşme framework	Foundry	Hızlı test, modern
Sözleşme kütüphanesi	OpenZeppelin + Solady	Çoktan denetlenmiş
Oracle	Chainlink	PoR desteği en olgun
Köprü (Faz 4)	LayerZero OFT	Merkezi havuz riski yok
Cüzdan saklama	Fireblocks MPC	Policy engine + HSM
Backend dili	Go + TypeScript	Operasyonel olarak basit
Veritabanı	PostgreSQL 16	ACID + zengin özellik
Event bus	NATS JetStream	Hafif, streaming
Web frontend	Next.js 15 + Tailwind	SEO + hız
Mobil	Swift + Kotlin + KMP	Native performans
KYC sağlayıcı	Sumsb + Jumio	İki sağlayıcı, yedek var
Bulut	AWS birincil + GCP yedek	Çoklu region
Container orkestrasyon	Kubernetes (EKS)	Bulut bağımsız

7. Güvenlik — kötü senaryolar ve cevaplarımız

Bir tokenize altın platformunda dört şey aynı anda korunmalı: kod, anahtarlar, fiziksel altın, ve uyum. Birini boş bırakırsak diğerleri işe yaramaz. İşte tehdit bazlı kısa cevaplar:

Olası tehdit	Ne yapıyoruz
Kontratta exploit	Çoklu imza + PoR kontrolü + formal verification + 3 bağımsız denetim
Kasada iç tehdit	4-göz kuralı, CCTV, dual control, çubuk başı etiket
Özel anahtar sızar	AWS CloudHSM L3 + Fireblocks MPC + cold storage
Kullanıcı phishing	Hardware wallet desteği, EIP-712 domain bağlama
Oracle manipülasyonu	Chainlink + 3+ kaynak medyan + sapma koruyucu
Reentrancy (kontrat oyunu)	OpenZeppelin ReentrancyGuard + check-effects-interactions
KYC by-pass (sahte kimlik)	Biyometrik + belge ağı analizi + çift vendor
API'ye DoS atağı	CloudFlare + rate limit + WAF
Bir ülkede regülatör baskını	Diğer üç jurisdiction ayakta, İsviçre yedek
Bağımlılık zinciri (npm/go)	Pinned deps, SBOM, Snyk, iç artifact registry

Pratikte ne anlama geliyor bunlar?

- **Sıcak cüzdan = az miktar:** Toplam altının en fazla %1'i. Günlük işlem için.
- **Soğuk cüzdan = ana hazine:** Çok imzalı, farklı şehirlerde, geofencing alarmlı.
- **Treasury Safe imzacıları:** 5 kişi, 3 farklı şehir, 2 farklı ülke. Hepsi Ledger donanım cüzdanı.
- **Anahtar rotasyonu:** Yılda bir, her olaydan sonra zorunlu.
- **Bug bounty:** Immunefi üzerinden — kritik bug 500 bin USD, yüksek 100 bin USD.
- **Incident response:** Sistem 1 saat içinde geri ayağa kalkmalı (RTO), en fazla 5 dakika veri kaybı (RPO).

8. Kim ne yapacak? — Başlangıç ekibi

Faz 0 ve 1 için toplam 13 kişi yetiyor. Şişirilmemiş, herkesin net bir görevi olan bir takım:

Rol	Adet	Ne yapıyor
Tech Lead / Chief Architect	1	Genel mimari, teknik kararlar
Smart Contract Engineer	2	Solidity + Foundry, kontrat tasarımı ve testi
Backend Engineer (Go)	3	Mikroservisler, mint/burn, compliance
Frontend Lead (Next.js)	1	Web uygulaması + verify portalı
Mobile Engineer	2	iOS (Swift) + Android (Kotlin)
SRE / DevOps	1	Kubernetes, CI/CD, gözlemlenebilirlik
Security Engineer	1	Tehdit modeli, audit hazırlığı, key management
QA / Test Engineer	1	E2E testleri, regresyon
Product Manager	1	Sipariş akışları, KYC akışları
Compliance Tech Liaison	1	Hukuk ile ürün arası köprü

Faz 2 ve sonrası: KYC operasyon, müşteri destek, business development, data analyst, ve üç ek arenanın yerel temsilcileri.

9. Hala karara bağlanmamış olanlar

Nisan 2026 toplantısında bazı şeyleri çözdük. Bazıları hâlâ düzenleyici görüşü bekliyor. Şeffaf olalım:

Çözülenler (kesin)

- **Hassasiyet:** 18 decimals — DeFi uyumu ve alt-gram fraksiyon için.
- **Self-custody:** Ülkeye göre değişir — TR'de custodial-only, CH/AE/LI'de Enhanced KYC sonrası serbest.
- **Minimum alım:** 1 gram (sistem üzerinden). DEX'te zaten fraksiyon serbest.
- **Fiziksel teslim minimumu:** 1 kg — LBMA çubuğunu bölmek pahalı.
- **Köprü modeli:** Faz 4'te yeniden değerlendirilecek; şimdilik LayerZero OFT default.

Hala açık olanlar

- **Yakım onayı:** 100 gramın altı otomatik mi, üstü onaylı mı? Henüz karar yok.
- **KVKK veri ikametgâhı:** Türk kullanıcı verisi yurt dışına çıkabilir mi? Hukuki görüş bekliyoruz.
- **Gas ödeme:** Kullanıcı ETH mi ödesin, biz mi ödeyelim (meta-tx)? v1'de EIP-2612 permit, v2'de paymaster planı var.
- **Layer 2 stratejisi:** Day-1 sadece Ethereum mi, yoksa Base/Arbitrum day-1 mi? Öneri: önce mainnet, sonra L2.

10. Tek sayfada özet

GOLD nedir?

Her token tam olarak bir gram altın. Dört ülkede lisanslı, ayda bir Big Four tarafından denetlenen, kendi rafinerisi olan bir dijital altın platformu.

Nasıl çalışıyor?

Sen para yatırırısın → kasadaki çubuğun bir kısmı sana tahsis edilir → 5 imzadan 3'ü tamam derse token cüzdanına gelir. Satarken tersi: token yakılır, çubuk boşa çıkar, paran hesabına döner.

Rakiplerden farkı?

1 gram minimum (1 ons değil), dört yetki alanı (TR/CH/AE/LI), kendi rafinerimiz, çubuk bazında izlenebilirlik, Merkle proof ile bağımsız doğrulama.

Nasıl yapılacak?

Altı fazlı, 24+ aylık plan. Önce Türkiye MVP, sonra İsviçre + otomatik denetim, sonra mainnet lansmanı, sonra global ölçek ve olgun ürün. Hiçbir adım atlanmıyor.

Ne kadar sürer, ne kadar tutar?

İlk MVP (TR arena, manuel denetim): 6 ay. Mainnet lansman (otomatik PoR + 3 güvenlik denetimi): 14 ay. Tam global ölçek (4 arena + çoklu zincir): 24+ ay. Başlangıç rezervi: 10 milyon USD. Başlangıç ekibi 13 kişi.

Detaya inmek istersen: **docs/system-design.md** (972 satır tam mimari), **docs/contracts/README.md** (kontrat spec), **docs/backend/README.md** (backend spec).

11. Rakipler: PAXG ve XAUT nasıl çalışıyor?

Tokenize altın dünyasında iki büyük oyuncu var: **PAXG** (Paxos Gold) ve **XAUT** (Tether Gold). Onları konuşmadan GOLD'un yerini anlamak zor. İkisini tek tek anlatayım, sonra yan yana koyalım.

PAXG — Paxos Gold

Paxos, New York merkezli bir kripto şirketi. PAXG'yi 2019'da çıkardı. Çalışma mantığı şöyle:

- **İhraç eden:** Paxos Trust Company, New York. NYDFS (New York Eyalet Finansal Hizmetler Departmanı) tarafından lisanslı — kripto dünyasının en sıkı regülatörlerinden biri.
- **Birim:** 1 PAXG = 1 troy ons altın (~31.1 gram). Yani küçük yatırımcı için yüksek bir giriş.
- **Kasa:** Londra'daki Brink's kasalarında, LBMA standartında 400-ons külçeler halinde.
- **Zincir:** Sadece Ethereum (ERC-20).
- **Denetim:** Aylık Withum firması tarafından attestation. Paxos'un sitesinden hangi külçenin senin olduğunu seri numarasıyla görebiliyorsun.
- **Fiziksel teslim:** 430 ons minimum (yaklaşık 13 kg, 2026 fiyatıyla ~30 milyon TL). Yani pratikte sadece kurumsal kullanıcı için.
- **KYC:** Sıkı — Paxos doğrudan satın almak için tam doğrulama, borsalardan alırsan borsa KYC'si.

XAUT — Tether Gold

Tether (USDT'nin arkasındaki şirket) 2020'de çıkardı. Mantık benzer ama önemli detaylar farklı:

- **İhraç eden:** TG Commodities Limited, British Virgin Islands. Yani offshore — NYDFS gibi sıkı bir regülatöre değil, BVI hafif çerçevesine bağlı.
- **Birim:** 1 XAUT = 1 troy ons altın (~31.1 gram). PAXG ile aynı.
- **Kasa:** İsviçre'de (Tether kesin lokasyon açıklamıyor). LBMA standartı külçeler.
- **Zincir:** Hem Ethereum (ERC-20) hem Tron (TRC-20) — Tron tarafı daha ucuz işlem.
- **Denetim:** Tether tarafından yayınlanan attestation. Tarihsel olarak BDO İtalya yapıyordu ama şeffaflığı PAXG kadar tutarlı değil.
- **Fiziksel teslim:** 50 XAUT (yaklaşık 1.55 kg) — PAXG'den çok daha erişilebilir, ama yine de küçük yatırımcının üstünde.
- **KYC:** Daha gevşek. Bazı kanallardan KYC yapmadan da alınabiliyor (Tether'in genel çizgisi).

Üçü yan yana

Özellik	PAXG	XAUT	GOLD
İhraç eden	Paxos (NY)	TG / Tether (BVI)	GOLD (TR/CH/AE/LI)
Düzenleyici	NYDFS	BVI offshore	CMB+FINMA+VARA+FMA
Minimum birim	1 ons (~31g)	1 ons (~31g)	1 gram
Kasa lokasyonu	Londra	İsviçre	4 kasa, 4 ülke
Rafineri	3. taraf	3. taraf	Kendi (Çorum)
Zincir	Ethereum	Ethereum + Tron	Ethereum (sonra çoklu)
Denetim	Aylık Withum	Düzensiz BDO	Aylık Big Four
Merkle proof on-chain	Hayır	Hayır	Evet
Fiziksel teslim min.	~13 kg	~1.55 kg	1 kg
KYC sıklık	Yüksek	Orta	Yüksek, ülkeye göre
Sigorta beyanı	Var	Açık değil	Lloyd's 500M USD
Yaklaşık piyasa değeri	~600M USD	~700M USD	Henüz yok

PAXG'nin artıları ve eksileri

- + NYDFS regülasyonu — kripto dünyasının en güvenilir regülatörü.
- + Aylık şeffaf denetim, sürekli.
- + Brink's Londra — kasada şüphe yok.
- + Likidite iyi — Binance, Kraken, Coinbase gibi büyük borsalarda var.
- – 1 ons minimum — Türk perakende yatırımcısı için yüksek (yaklaşık 70 bin TL).
- – Tek jurisdiction (ABD) — politik risk. SEC bir gün 'durdurun' derse ne olur?
- – Fiziksel teslim 430 ons — pratikte sadece kurumsal.
- – Rafineri ve kasa hep üçüncü taraf — kendi tedarik zinciri yok.

XAUT'un artıları ve eksileri

- + Fiziksel teslim 50 ons — PAXG'den çok daha erişilebilir.
- + İsviçre kasası — politik olarak nötr ülke.
- + Ethereum ve Tron'da birden — Tron tarafı çok ucuz işlem.
- + Bazı kanallarda KYC'siz alım mümkün (gri alan ama gerçek).
- – Tether ile bağlı — USDT'nin geçmişteki rezerv tartışmaları itibarı zedeliyor.
- – BVI regülasyonu — offshore, sıkı bir denetleyici yok.
- – Şeffaflık raporları PAXG kadar disiplinli değil.
- – Likidite PAXG'den daha düşük.

Peki GOLD nereye oturuyor?

PAXG güvenilir ama büyük kurumsal odaklı, küçük yatırımcı için uzak. XAUT erişilebilir ama Tether itibarı taşıyor. GOLD bu iki ucun ortasında olmaya çalışıyor:

- **Erişilebilirlik:** 1 gram minimum, XAUT'tan bile düşük.
- **Güvenilirlik:** 4 ayrı düzenleyici, Big Four denetimi, on-chain Merkle proof — PAXG'den bile bir adım öteye.
- **Bağımsızlık:** Kendi rafinerimiz (Çorum) — ne PAXG'de ne XAUT'ta var.
- **Politik dayanıklılık:** Bir ülke kapanırsa diğer üçü çalışır. PAXG (ABD-only) ve XAUT (BVI tek) buna sahip değil.
- **Eksisi:** Henüz canlı değil, marka tanınmamış, likidite sıfırdan kurulacak. Bu da başlangıçtaki en büyük zorluk.

Tek cümlede konum

PAXG = güvenilir ama küçük yatırımcıya uzak. XAUT = erişilebilir ama Tether gölgesi taşıyor. GOLD = 'PAXG'nin güveni + XAUT'un erişilebilirliği + kendi rafinerimiz + 4 jurisdiction' formülünü deniyor.

11.2. Blokzincir tarafından üçü yan yana

Buraya kadar konuştuğumuz fark çoğunlukla iş tarafıydı. Asıl tokenize altın işinin ruhu kontratlarda gizli. PAXG ve XAUT'un Ethereum üzerindeki sözleşmeleri açık ve okunabilir; aşağıdaki tablo onlardan çıkarıldı:

Özellik	PAXG	XAUT	GOLD
Deploy yılı	2019	2020	2026 (planlı)
Solidity sürümü	0.5.x	0.4.17	0.8.24
Decimals	18	6	18
Upgrade pattern	Custom delegate-call	Deprecation flag	UUPS + 7 gün Timelock
Mint yetkisi	Tek supplyController	Tek owner	K-of-N (3/5)
On-chain reserve gate	Yok	Yok	Var (35 gün taze)
Merkle proof on-chain	Yok	Yok	Var
EIP-712 attestation	Yok	Yok	Var
EIP-2612 permit	Yok	Yok	Var
On-chain KYC kontrolü	Yok (off-chain)	Yok (off-chain)	Her _update'de
Travel Rule on-chain	Yok	Yok	Var (eşik bazlı)
Freeze + wipe yetkisi	Var	Var (blacklist)	Freeze var, wipe yok
Custom errors (gas)	Yok	Yok	Var
ERC-7201 storage	Yok	Yok	Var

Üç kritik fark

Tablo uzun ama özü üç maddede toplanabilir:

- **1. Mint nasıl kontrol ediliyor?** PAXG ve XAUT'ta tek bir cüzdan adresi yetkili. O adres ele geçirilirse veya kötüye kullanılırsa sistem biter. GOLD'da kontrat seviyesinde 5 imzacıdan 3'ü onaylamadıkça hiçbir token basılmıyor — tek bir kişi mint yapamaz, kontrat reddediyor.
- **2. Rezerv kontrolü zincirde mi, off-chain mi?** PAXG ve XAUT'ta 'kasada altın yoksa basamazsın' kuralı issuer'ın iç prosedüründe — kontrat soruyu sormuyor. GOLD'da MintController her execute'ta totalSupply + amount > attestedGrams ise revert ediyor, ayrıca son denetim 35 günü geçmişse de revert.
- **3. Kullanıcı kendi başına doğrulayabilir mi?** PAXG/XAUT'ta 'benim altınım hangi çubukta' sorusunun cevabı issuer'ın websitesinde — onlara güvenmek zorundasın. GOLD'da ReserveOracle.verifyBarInclusion(index, leaf, proof) zincirde çağrılabilir, matematik sana 'evet bu çubuk o ayki denetimdeydi' diyor. Issuer'a güvenmek zorunda değilsin.

PAXG'nin teknik tarafı — kısa kısa

- **Kontrat adresi:** 0x4580...4F78a (Ethereum mainnet).
- **Mimari:** Paxos kendi delegate-call proxy pattern'i. OZ değil.
- **Roller:** owner, assetProtectionRole, supplyController, feeController, feeRecipient, pauser.
- **Wipe yetkisi:** assetProtectionRole bir cüzdanı dondurup wipeFrozenAddress ile bakiyeyi silebilir. NYDFS düzenlemesi için var ama merkezi güç.
- **Fee:** Kontratta feeRate parametresi var, şu an %0 ama issuer açabilir.
- **Audit:** ChainSecurity (kontrat) + Withum (aylık attestation).

XAUT'un teknik tarafı — kısa kısa

- **Kontrat adresi:** 0x6874...82F38 (Ethereum mainnet); ayrıca Tron'da TRC-20.
- **Mimari:** USDT TetherToken pattern'i — BasicToken + StandardToken + Pausable + BlackList. Yani USDT'nin altın versiyonu denebilir.
- **6 decimals:** DEX entegrasyonlarında dikkat ister — 18 değil.
- **Blacklist:** Owner istediği adresi blackliste atıp destroyBlackFunds ile bakiyesini yakabilir. USDT'deki ile aynı.
- **Deprecation flag:** Owner kontratı 'deprecated' işaretleyip yeni adrese yönlendirebilir — pseudo-upgrade.
- **Fee:** basisPointsRate + maximumFee parametreleri (USDT'den miras), şu an 0.

12. Blokzincir tarafına teknik bakış (GOLD)

Bu bölüm yazılım geliştiriciler ve teknik denetçiler için. Eğer kod tarafıyla işin yoksa atlamak serbest. Burada kontratların gerçekten ne yaptığını madde madde anlatacağız.

12.1. Genel teknik yığın

- **Dil:** Solidity 0.8.24, Cancun EVM. Built-in overflow check var (0.8+).
- **Compiler ayarları:** via_ir = true, optimizer 10.000 runs. via_ir özellikle MintController gibi karmaşık kontratta stack-too-deep hatalarını çözüyor.
- **Framework:** Foundry. Fuzz testler default 1.000 run, CI'da 10.000. Invariant testler 256 run + 100 depth.
- **Kütüphaneler:** OpenZeppelin v5 (audit havuzu en geniş) + Solady (kritik path'lerde gas optimizasyonu).
- **Storage pattern:** ERC-7201 'namespaced storage' — her kontratın storage'ı keccak hash ile izole slot'a yazılıyor. Upgrade çakışması fiziksel olarak imkânsız.
- **Custom errors:** Tüm revert'ler string yerine custom error. Hem gas hem hata yakalama daha iyi.
- **Bytecode hash:** none, cbor_metadata false — deterministik build için.

12.2. Roller tablosu — kim ne yapabilir?

GOLD'da on iki ayrı rol var. Hiçbir adresin birden fazla kritik rolü almaması ilkesi — kuvvetler ayrılığı:

Rol	Verildiği yer	Ne yapabilir
DEFAULT_ADMIN	Treasury Safe	Rol verir/alır
TREASURY_ROLE	Treasury Safe	Parametre değişikliği, controller atama
UPGRADER_ROLE	Treasury Safe	UUPS _authorizeUpgrade
PAUSER_ROLE	Acil müdahale ekibi	Token.pause() — sadece dondurma
MINT_PROPOSER	Mint/Burn Service	Mint önerisi açar
MINT_APPROVER	5 ayrı imzacı	Önerilen mint'i onaylar
MINT_EXECUTOR	Operations bot	Onaylanmış execute eder
BURN_OPERATOR	Mint/Burn Service	Redemption burn başlatır
COMPLIANCE_OFFICER	Uyum müdürü	Freeze, sanctions, Travel Rule, operator burn imzası
KYC_WRITER	KYC Service	WalletProfile yazar
AUDITOR_ROLE	Big Four cüzdanı	ReserveOracle.publish ile attestation yayınlar
FEE_RECIPIENT	Treasury Safe	Mint/burn fee'sini alır

12.3. Mint akışının zincir üstü mantığı

executeMint çağrıldığında kontrat şu beş kontrolü yapıyor — biri bile düşerse revert:

- **1. Onay sayısı:** `p.approvers.length >= approvalThreshold` (default 3). Aksi halde `InsufficientApprovals` revert.
- **2. Compliance:** `ComplianceRegistry.canMint(to, amount, jurisdiction)`. Alıcı dondurulmuş, sanctions'lı veya KYC süresi geçmişse false döner.
- **3. Reserve freshness:** `ReserveOracle.timeSinceLatest() > maxReserveAge` (default 35 gün) ise `StaleReserveAttestation` revert.
- **4. Reserve invariant:** `token.totalSupply() + grossAmount <= oracle.latestAttestedGrams()`. Aksi halde `ReserveInvariantViolated` revert.
- **5. Rate limit (opsiyonel):** Bir pencere içinde basılan toplam miktar konfigüre edilmiş tavanı aşamaz.

Bunlar geçtikten sonra **CEI pattern** uygulanıyor: önce state update (`ProposalStatus.EXECUTED + allocationUsed = true`), sonra dış çağrı (`token.mint`). Mint sonucu 25 bps fee Treasury'ye, kalan kullanıcıya gidiyor. `ReentrancyGuard`'la ayrıca korunmalı.

12.4. ReserveOracle neden upgradeable değil?

Diğer tüm kontratlar UUPS proxy ile upgrade edilebilir. ReserveOracle bilinçli olarak **immutable**. Sebep: denetim geçmişinin değiştirilemezliği sistemin can damarı. Eğer biri ReserveOracle'ı upgrade edebilirse geçmiş attestation'ları silebilir. Bunu imkânsızlaştırmak için:

- Kontratta hiç UUPS init yok, `_authorizeUpgrade` fonksiyonu yok.
- `Attestation[]` private `_attestations` — sadece push var, delete yok.
- `publish()` içinde monotonicity check: yeni timestamp eski timestamp'ten kesinlikle büyük olmalı.
- Geleceğe tarihli attestation kabul edilmiyor (± 1 saat tolerans, NTP sapması için).
- Bug bulunursa: yeni ReserveOracle deploy edilir, `MintController.setOracle()` ile bağlanır. Eski kontrat blockchain'de kalır, geçmiş okunabilir.

12.5. EIP-712 attestation yapısı

Denetçinin imzaladığı veri yapısı sabit. `publish()` çağrısında kontrat bu hash'i yeniden hesaplayıp `ECDSA.recover` ile imzayı doğruluyor. Yapı:

- **timestamp:** attestation üretildiği zaman (saniye).
- **asOf:** kasanın hangi an itibarıyla sayıldığı (timestamp'ten önce).
- **totalGrams:** dört kasanın toplam altın miktarı, $1e18$ ile çarpılmış.
- **merkleRoot:** her çubuğun seri/ağırlık/saflık/kasa hash'lerinden oluşan ağacın kökü.
- **ipfsCid:** tam denetim paketinin (PDF, fotoğraflar, CSV) IPFS adresi.

- **auditor:** imzayı atan denetçinin Ethereum adresi. AUDITOR_ROLE'üne sahip olmalı, aksi halde UnknownAuditor revert.

12.6. Kullanıcı Merkle proof doğrulama akışı

verify.gold.example portalında 'altınımı doğrula' tuşuna basıldığında arka planda olan şu:

- Backend kullanıcının cüzdanını → bar_allocations → gold_bars → vault zincirinden geçirip son audit_snapshot'taki çubuk leaf'lerini buluyor.
- Her çubuk için Merkle proof veriyor: leaf = keccak256(barSerial, weightGrams, purity999, vaultCode, refinerLBMAId).
- Kullanıcı isterse browser'da Ethers/Viem ile ReserveOracle.verifyBarInclusion(attestationIndex, leaf, proof) çağırıyor.
- Kontrat MerkleProof.verifyCalldata(proof, root, leaf) çalıştırıp true/false dönüyor.
- true ise: kullanıcı 'o çubuk gerçekten o ayki denetimdeydi' garantisini matematiksel olarak almış oluyor — siteye değil, Ethereum'a güveniyor.

12.7. GoldToken._update kancası

OpenZeppelin v5 ile transfer/mint/burn akışları tek bir _update hook'unda birleşti (eski _beforeTokenTransfer yerine). Bu hook şu sırayla çalışıyor:

- **whenNotPaused modifier:** Pauser kontratı durdurmuşsa transfer yapılmaz.
- **Sadece transfer ise (from ve to sıfır değil):** ComplianceRegistry.canTransfer(from, to, value) çağrılır.
- **canTransfer false dönerse:** Hangi kurala takıldığını bulup spesifik revert at — WalletFrozen, SanctionsHit, KycRequired, TravelRuleRequired. Genel NotAuthorized yerine spesifik mesaj gas'ı biraz artırır ama debug'ı kolaylaştırır.
- **Mint path (from=0):** Sadece mintController adresi mi kontrolü; compliance burada değil MintController'da yapılıyor.
- **Burn path (to=0):** Sadece burnController adresi mi kontrolü.

12.8. BurnController'da dual-control operator burn

Olağan kullanıcı redemption'ında operatör tek başına burn yapabiliyor. Ama 'operator burn' diye ikinci bir akış var — mahkeme emriyle dondurulan bir cüzdanın bakiyesini yakmak gerekirse. Bu çift kontrol ile yapılıyor:

- BURN_OPERATOR_ROLE çağrısı yapıyor.
- Ama beraberinde COMPLIANCE_OFFICER_ROLE'üne sahip birinin EIP-712 imzası gerekiyor.
- İmza şu yapı üzerinde: OperatorBurn(from, amount, reasonHash, nonce, deadline).
- Nonce her kullanımda otomatik artıyor — replay imkânsız.
- Deadline geçmişse DeadlineExpired revert — eski imza geçersiz.
- Yani iki farklı kişinin onayı olmadan operator burn yapılamaz. PAXG/XAUT'taki tek kişilik wipe yetkisinden farklı.

12.9. UUPS upgrade + 7 gün Timelock

Token, ComplianceRegistry, MintController, BurnController UUPS proxy ile upgrade edilebilir. Akış:

- Treasury Safe yeni implementation'a upgrade önerir (Safe transaction olarak).
- Safe'in policy engine'i 7 gün timelock'u uyguluyor — bu süre içinde topluluk inceleyebiliyor.
- Timelock dolduğunda 3/5 imzacı execute ediyor.
- Kontrat seviyesinde _authorizeUpgrade fonksiyonu UPGRADER_ROLE kontrolü yapıyor, ek bir kontrol katmanı.
- Tüm upgrade'ler OpenZeppelin Defender üzerinden monitör ediliyor, anormal aktivite Slack'e alert düşürüyor.

12.10. Fee modeli

GOLD'da iki fee var, ikisi de 25 bps (0.25%):

- **Mint fee:** MintController.executeMint sırasında. Gross amount'tan fee düşülür, kalan kullanıcıya. Fee Treasury'ye mint edilir (ayrı bir mint, jurisdiction tag korunuyor).
- **Burn fee:** BurnController.requestRedemption sırasında. Tam amount yakılıyor; off-chain settlement'ta (amount - fee) gram altın veya nakit kullanıcıya gidiyor. BurnFeeCollected event'i denetlenebilirlik için emit ediliyor.
- **Transfer fee:** SIFIR. Token'daki transferlerde hiçbir fee yok. PAXG'nin aksine kontratta feeRate parametresi de yok — issuer açma ihtimali bile yok.

Sonuç: kontrat seviyesinde GOLD'un üç farkı

1. Çoklu imza zincirde zorlanıyor — tek bir anahtar çalınması sistemi düşürmüyor.
2. Rezerv kontrolü kontratta — issuer kasayı dolu söylemese bile MintController kabul etmiyor.
3. Kullanıcı doğrulaması kontratta — verify portalına değil, Ethereum matematiğine güveniliyor.